

現況架構 —— 今天實際在跑的東西

UPS Reprice Platform · 依 index.html、auth-config.js 與 supabase/*.sql 目前的內容繪製

LOCAL_MODE = true

● 使用中 ○ 存在但沒在用 ✕ 被擋住 △ 注意

1 · 網站怎麼送出去

GitHub 倉庫
分支:main
pre-commit hook 擋金鑰

靜態主機
Vercel · Cloudflare Pages · Netlify
沒有 build 步驟,檔案原樣送出

送到瀏覽器的 4 個檔案
index.html · auth-config.js
supabase-js-2.112.3.js · xlsx-0.18.5.full.min.js

在 repo 裡,但不會送出去
authconfig.js —— 沒有地方載入它
supabase/*.sql · functions/ · *.py

① 開網頁時載入

2 · 使用者的瀏覽器 —— 這裡沒有伺服器

已載入的檔案

index.html
介面 + 整套計價引擎
約 602 KB,單一檔案
分頁:匯入 · 附加費 · 尺寸 ·
通路 · 需求附加費 · 帳單歷史 ·
代碼查詢 · 儀表板 · 設定 · Admin

supabase-js-2.112.3.js
有載入,但只用來呼叫 RPC

xlsx-0.18.5.full.min.js
讀寫 Excel 檔

auth-config.js
{ url, anonKey }
△ 裡面沒有 **authMode**,所以
LOCAL_MODE = true

登入 —— 本機帳號模式

① 使用者輸入帳號 + 密碼
② `h = sha256(帳號 + ":" + 密碼)`
③ 跟 index.html 裡的 LOCAL_ACCOUNTS[]
陣列逐筆比對
④ 對上了就組出身分:
`ME.id = "local::" + 帳號`
`ME.role = "admin" | "user"`
`ME.sync = sha256("cfg-sync::" +
帳號 + ":" + 密碼)`
⑤ 登入狀態 → sessionStorage
勾了「保持登入」才寫 localStorage
`AUTH = null`
沒有建立任何 Supabase 登入用戶端
`SYNC = anon` 用戶端,只呼叫 RPC
△ 密碼雜湊跟著網頁一起送出去
△ 加人或停權 = 改檔案 + 重新部署

計價流程 —— 全在記憶體

輸入(從不上傳)
UPS 帳單 —— `xlsx / xls / csv`
沒有標題列的 CSV 也認得出來
合約費率表 —— 一服務一檔
或一次丟好幾個

處理 —— 在瀏覽器記憶體裡
解析 → 材積重 → 底價 →
附加費(AHS / LPS / 需求) →
燃油 → 通路利潤

輸出 —— 由 `xlsx.js` 寫出
客戶報表.xlsx
內部對帳單.xlsx
含成本、利潤與毛利率

✓ 帳單檔案從來沒有離開過
這台電腦

這台電腦上的個人資料

localStorage
`ups_reprice_cfg::<ME.id>`
`...hist::<ME.id>` 期別索引
`...histinv::<ME.id>` 帳單清單
`ups_reprice_log` 活動紀錄

IndexedDB
`<db>::<ME.id>` 逐筆明細

sessionStorage
`ups_reprice_local_session`

△ 每一把 **key** 前面都掛著 **ME.id**,
今天它是 "local::<帳號>"。
身分一換,前綴就換,程式到
新前綴底下找,自然是空的 ——
東西還在,在舊前綴底下。
同台電腦換人登入靠的就是它。

3 · Supabase 專案 —— 目前只透過 RPC 進出

Auth 認證 ○ 沒有在用

auth.users 裡可能已經有帳號,但這個
網站從來沒有透過它登入過。
· 從來不建立 AUTH 用戶端
· `signInWithPassword()` 從沒被呼叫
· `record_login()` 從沒被呼叫
· `app_metadata.role` 從沒被讀取
· 不會發出、也不會更新 session

△ 後台的公開註冊可能還開著。
Auth 沒在用的時候沒差 —— 但你切
過去的那一刻就有差。先關掉它。

Database(Postgres + 列級安全 RLS)

local_settings ● 使用中
RLS 開著,但一條 policy 都沒有 —— anon
既不能讀、不能寫,也不能列出這張表
↳ `local_settings_get(k) / _put(k, cfg, name)`
SECURITY DEFINER · k 必須符合
`^[0-9a-f]{64}$` —— k 就是 ME.sync

local_history ● 使用中
↳ `local_history_list / _get / _put / _del`
在瀏覽器裡 gzip 壓縮 · 只增或覆蓋:清掉
某一台的資料,不會刪掉雲端那一份

login_history ○ **profiles** ○ **user_settings** ○
SQL 跑完這三張表就存在,但這個模式下
沒有任何一段程式碼會碰到它們

Edge Functions

ups-address ● 使用中(若已部署)
`POST { name, address, city, state, postal,
country } → { class: R | C | U }`
`UPS_CLIENT_ID / UPS_CLIENT_SECRET` 存成函式
的 secret,瀏覽器永遠看不到它們
端點網址填在「帳單歷史」分頁裡

admin-users ✕ 連不到
它要一個 Supabase 登入 token 才能證明來
人是主帳號。本機模式沒有 token,所以
Admin 分頁只列出寫死的帳號,不能新增。

✓ **service_role** 金鑰只存在這裡 ——
永遠不會送到瀏覽器

理想架構 —— Supabase 登入打開之後

綠色 = 程式已經寫好,只差設定。橘色 = 還要寫。其餘一切與現況完全相同。

authMode: "supabase"

● 切過去就能用 ▲ 還要寫 △ 注意

1 · 網站怎麼送出去

GitHub 倉庫

分支:main
不變

靜態主機

不變 —— 一樣送那 4 個檔
Site URL 要註冊到 Supabase

唯一要改的檔案

auth-config.js → { authMode: "supabase", url, anonKey }
index.html 一個字都不用改 —— 程式本來就在裡面

部署到 **Supabase**,不是網站
schema.sql · login_history.sql · 2 支函式
▲ 刪掉 authconfig.js(沒用的死檔)

① 開網頁時載入

2 · 使用者的瀏覽器 —— 身分改由外面決定

已載入的檔案

index.html

跟現在同一個檔,一個字都沒改
兩條登入路徑本來就都在裡面;
一行設定決定走哪一條

supabase-js-2.112.3.js

開始真的在做事:登入 + RLS

xlsx-0.18.5.full.min.js

不變

auth-config.js

```
{ authMode: "supabase",  
  url, anonKey }
```

✓ 這裡仍然只有公開的值
service_role 金鑰不會出現
pre-commit hook 也在守著

登入 —— Supabase Auth

- ① 使用者輸入帳號 + 密碼
- ② loginEmail():輸入沒有 "@",就補成 @ups-reprice.invalid
- ③ signInWithPassword({ email, password })
- ④ Supabase 回傳一組 session:
access_token —— JWT,自動換新
app_metadata.role → "admin" | "user"
user_metadata.display_name
- ⑤ ME.id = 那個帳號的 UUID
- ⑥ AUTH.rpc("record_login", { p_user_agent })

AUTH = Supabase 用戶端,狀態保留
SYNC = AUTH
一條連線、一個身分 —— 同步鑰匙
那套置物櫃不再使用

- ✓ 沒有密碼或雜湊跟著網頁送出
- ✓ 加入、停權都不用重新部署

計價流程 —— 完全不變

輸入(從不上傳)

UPS 帳單 —— xlsx / xls / csv
合約費率表

處理 —— 在瀏覽器記憶體裡
解析 → 材積重 → 底價 →
附加費 → 燃油 → 通路利潤

輸出 —— 由 **xlsx.js** 寫出
客戶報表.xlsx
內部對帳單.xlsx

✓ 計價這件事一點都沒有上雲。
Supabase 永遠看不到任何一列
帳單明細或合約費率。

這是最該保護的部分,而這次
切換完全沒有碰到它。

本機資料 —— 唯一的地雷

key 跟今天一模一樣,只有前綴
那個值變了:

切換前 local::<帳號>

切換後 一組 UUID

▲ 缺口 1 —— 認領舊資料

第一次用 Supabase 登入時:如果新
前綴底下是空的,而這台電腦有
local::<帳號> 的資料,就認領過
來 —— 設定、期別索引、帳單清單
和 IndexedDB 資料庫。
index.html 的註解自己就標了還沒寫。

不用寫程式的暫時解法:
切換前把設定匯出成檔案。
第一次登入後再匯入回來。
先在 preview 網址試,再改正式站。

3 · Supabase 專案 —— 現在是身分的來源

Auth 認證 ● 啟用

Email provider 開啟
公開註冊關閉 ← 先做這一步
帳號在後台建立時要勾
「Auto Confirm User」

auth.users

raw_app_meta_data.role = admin | user
只有 service_role / SQL 改得動 ——
所以這個角色才可以信
raw_user_meta_data.display_name
使用者改得動,所以絕不放角色

△ @ups-reprice.invalid 的帳號收不到
重設密碼的信。真的需要就用一個
收得到信的 email 地址。

Database(Postgres + 列級安全 RLS)

user_settings

upsert / select where user_id = auth.uid()
裝那個帳號自己的合約費率設定

profiles

由 auth.users 上的觸發器同步;這裡的 role
欄位只是副本,永遠不是權限的依據

login_history

↳ record_login(p_user_agent)
SECURITY DEFINER —— 使用者 id、email 和時間
都是從驗證過的 JWT 取的,不是請求裡送的
瀏覽器完全不能寫這張表

▲ 缺口 2 —— 這個模式下帳單歷史沒有雲端同步

Edge Functions

admin-users

列出 · 新增 · 改角色 · 刪除
驗證來人的 JWT,而且必須是
app_metadata.role = "admin"
→ 不是的話,連 body 都不看就回 403
△ 要把「**Enforce JWT verification**」關掉 ——
函式自己會驗,而且驗得更嚴

ups-address

跟今天完全一樣

▲ 還沒寫的部分

- 1 · 第一次登入時認領這台電腦的舊資料
- 2 · Supabase 模式下的帳單歷史同步
- 3 · 刪掉沒用的 authconfig.js

現況 → 理想:到底改了什麼

一行設定就把左欄變成中欄。右欄是那一行不會幫你做的事。

項目	現況	理想	要做的事
模式開關	<code>auth-config.js</code> 裡沒有 <code>authMode</code> ,所以 <code>LOCAL_MODE = true</code>	加上 <code>authMode: "supabase"</code> ;兩條路的程式碼本來就都在 <code>index.html</code> 裡	改一個檔、重新部署。把那一行刪掉就退回來。
密碼存在哪	SHA-256 雜湊寫在 <code>LOCAL_ACCOUNTS[]</code> ,跟著網頁一起送出。以前的明碼還留在 git 歷史裡。	Supabase Auth 保管。沒有任何密碼形狀的東西送到瀏覽器。	每個帳號都在後台用全新的密碼建立。曾經進過 repo 的密碼一律作廢。
誰進得來	只有寫死的那幾個帳號。公開註冊的設定無所謂,因為 Auth 根本沒在用。	只有你親手建的帳號 —— 前提是公開註冊已經關掉。	Authentication → Providers → Email → 關掉註冊。切換之前做,不是之後。
帳號 ID (ME.id)	<code>"local::<帳號>"</code>	Supabase 給的那組 UUID	缺口 1 —— 每一把 localStorage key 和 IndexedDB 的名字都掛著它。目前沒有任何搬遷程式。
加入 / 移除人	改 <code>index.html</code> 、commit、重新部署。在部署上線之前,那個人還進得來。	後台,或 App 裡的 Admin 分頁。他手上的 token 一過期就進不來。	想在 App 裡管就要部署 <code>admin-users</code> ;只用後台的話什麼都不用做。
角色	寫死陣列裡的 <code>role</code> 欄位 —— 任何人打開網頁都看得到	<code>app_metadata.role</code> ,寫在 JWT 裡。使用者自己改不動那一欄。	一個管理者跑一次 <code>update auth.users</code> 。跑完要登出再登入 —— 角色是跟著 token 走的。
登入狀態	<code>sessionStorage</code> 裡的一段 JSON(勾了「保持登入」就進 <code>localStorage</code>)	Supabase 的 session,token 會自動換新	什麼都不用做,用戶端自己處理。
費率設定同步	<code>local_settings</code> ,走兩個 SECURITY DEFINER 函式,鑰匙是 <code>sha256("cfg-sync::"+帳號+"::"+密碼)</code>	<code>user_settings</code> ,一個帳號一列,RLS 依 <code>auth.uid()</code>	跑 <code>supabase/schema.sql</code> 。注意:之前存在同步鑰匙底下的設定不會跟過來 —— 切換後再存一次。
帳單歷史同步	<code>local_history</code> 的 RPC —— 有在用,gzip 壓縮,只增或覆蓋	沒有。 <code>histPush/histPull</code> 不是 <code>LOCAL_MODE</code> 就直接跳出。	缺口 2 —— 需要一張依 <code>auth.uid()</code> 的表加 RLS ,做 local_history 已經在做的事。不補就是功能倒退。
登入紀錄	本機的活動紀錄 —— 只有這一台瀏覽器	<code>login_history</code> ,由 <code>record_login()</code> 寫入;身分和時間由伺服器從 JWT 取;只有主帳號讀得到	跑 <code>supabase/login_history.sql</code> 。失敗的嘗試和 IP 仍然要看 Supabase 自己的 Auth Logs。
Admin 分頁	只能列出寫死的帳號,不能改	透過 <code>admin-users</code> 完整管理帳號	部署函式,然後把它的「Enforce JWT verification」關掉 —— 函式自己驗來人,比平台那層更嚴。
地址查詢	<code>ups-address</code> Edge Function —— UPS 金鑰存成函式 <code>secret</code>	完全不變	什麼都不用做。
計價引擎	完全在瀏覽器裡跑。帳單和合約費率永遠不會到 Supabase —— 切換前後都一樣。		什麼都不用做。這正是這次切換刻意不去碰的部分。
沒用的設定檔	<code>authconfig.js</code> 存在,但沒有任何地方載入它。改它不會有任何效果。	刪掉。	缺口 3 —— 刪掉它,讓設定只有一個檔、一個地方要看。

動作順序

1. 把現在的設定匯成檔案。
2. 關掉公開註冊。
3. 建立帳號 —— 記得勾 **Auto Confirm User**。
4. 幫主帳號設 `app_metadata.role`。
5. 跑 `schema.sql` 和 `login_history.sql`。
6. 部署兩支 Edge Function;把 `admin-users` 的強制 JWT 驗證關掉。
7. 設定 Site URL 與 Redirect URLs。
8. 先在 preview 網址切 `authMode`。
9. 登入、把設定匯回來、確認 Admin 分頁在。
10. 再改正式站。

怎麼知道成功了

- 標題列的 BUILD 日期往前走了 —— 沒走就是拿到快取的舊頁,不是切換失敗。
- 故意打錯密碼,失敗是在 *Supabase* 那邊發生,不是網頁立刻擋下來。
- 主帳號看得到 Admin 分頁,一般帳號看不到。
- Admin 分頁列得出真的帳號 —— 這證明 `admin-users` 通了。
- 第二次登入會出現在 `login_history` 裡。

要退回去

把 `auth-config.js` 裡的 `authMode` 那一行刪掉,重新部署。網站回到本機帳號模式,原本那些掛在 `local::` 前綴底下的本機資料又看得到了。

試用期間寫進 Supabase 的東西不會因為退回去而消失 —— 兩種模式讀的是不同的表。

唯一回不去的是你建的那些帳號和密碼 —— 它們會留在 Supabase 裡閒置,直到你下次再切過去。